



Risk Exposure Summary

Prepared by: Luigi Falconi, CISO

July 31st, 2025

Table of Contents

Executive Summary	3
Key Terms	3
Archived Web Content: Employee Information	4
Internal Leak	5
Exposed Services.....	7
Social Networks	10
Leaked Internal Files & Credentials.....	12
Cloud Storage	14
Conclusion	15



Executive Summary

The purpose of this Risk Exposure Summary is to identify critical areas of organizational exposure across publicly accessible digital footprints and internal risk surfaces within Falconi's cyber environment. The report below details various exploitations adversaries may try to take advantage of, to exploit Falconi's sensitive data and misconfigured our assets. The following are detailed with possible vulnerabilities as well as mitigations for them: Archived Web content, Internal Leaks, Exposed Services, Social Networks, Leaked Internal Files, and Cloud Storage.

As a sports agency responsible for managing sensitive player information, contracts, and communications, Falconi must maintain strong defenses against evolving cyber threats. Being able to understand how web-based resources can be discovered by OSINT to identify internal systems and information helps us better understand how to improve our own vulnerabilities, as well as understanding attack behavior from adversaries.

Key Terms

OSINT	Open-Source Intelligence where information is collected from publicly available sources that include websites, articles, and social media platforms. Commonly used in Cybersecurity.
Metadata	A set of data that describes and gives information about other data
Exiftool	Open-source command line tool that is used to read, write, and edit data in files. Tool is often used in digital forensics.
Way Back Machine	The Wayback Machine is a digital archive of the World Wide Web, allowing users to view past versions of websites.
API Keys	Unique identifiers used to authenticate and authorize access to application programming interfaces (API). If exposed, attackers can use them to interact with



	backend services, which often bypasses standard login procedures.
--	---

Archived Web Content: Employee Information

Archived versions of Falconi’s “Meet the Team” page, captured in 2017 are still accessible via the Wayback Machine. This page disclosed the full names, job titles, and corporate email addresses of multiple employees, including senior and technical staff. This information could enable attackers to craft highly targeted phishing campaigns, impersonation attempts, or credential stuffing attacks using the exposed email format (first.last@falconi.com).

Additionally, the page's footer (visible in the HTML source) contains a comment referencing internal infrastructure: internal.falconi.local/gitlab. This may point to a self-hosted code repository, potentially still in use or forgotten, introducing further exposure if misconfigured or externally reachable.

Findings:

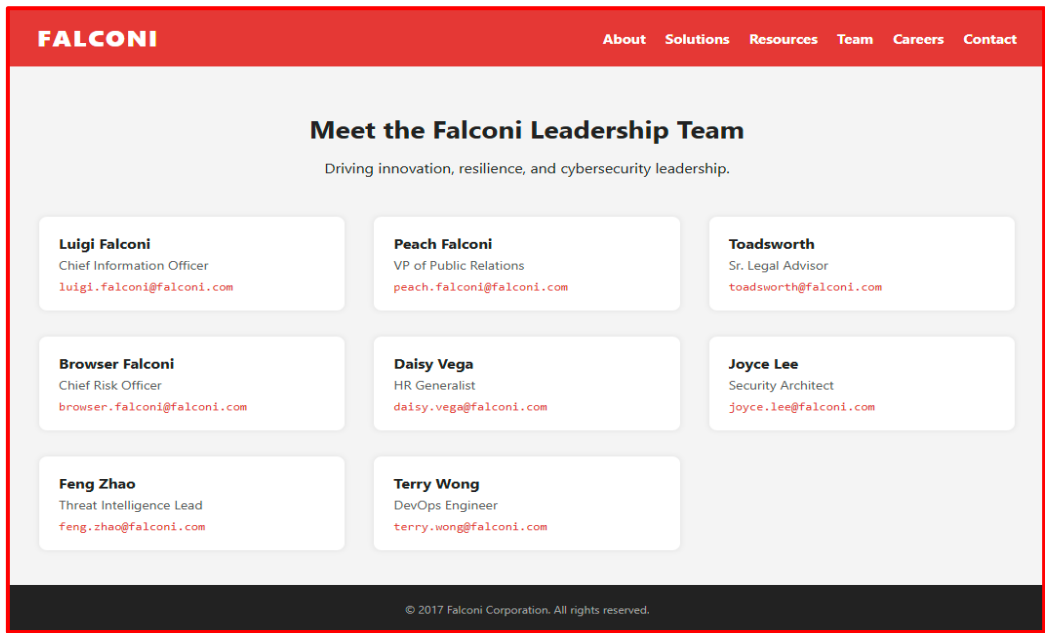


Figure 1: Archived Falconi “Meet the Team” page (2017 Wayback Machine snapshot)



```
<footer>  
  © 2017 Falconi Corporation. All rights reserved.<br>  
  <!-- Internal HR Dashboard v1.8 | GitLab: internal.falconi.local/gitlab -->  
</footer>
```

Figure 2: Page source showing internal GitLab URL reference in HTML comment

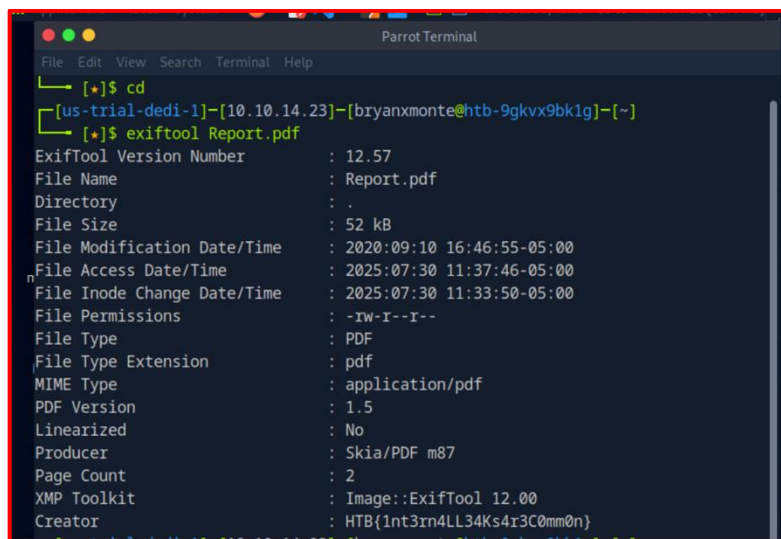
Recommended Mitigation Response:

- Submit a takedown request to archive.org to remove sensitive snapshots
- Replace public team directories with contact forms or general department emails
- Sanitize HTML templates to remove comments referencing internal infrastructure
- Include this scenario in phishing and impersonation awareness training for all staff

Internal Leak

Leaks of any kind can either be accidental, intentional, or forced. However, for most accidental leaks, unfamiliarity with IT knowledge can lead to publishing confidential data. Three instances in which confidential data could be leaked come from the file's metadata, or poorly hidden internal applications to name a few. These instances could leak some of Falconi's highly sensitive data such as Falconi's internal software & operating systems, names, email addresses, locations, date & time for internal events, and other security-related information.

Findings:



```
Parrot Terminal
File Edit View Search Terminal Help
[*]$ cd
[us-trial-dedi-1]-[10.10.14.23]-[bryanxmonte@htb-9gkvx9bk1g]-[~]
[*]$ exiftool Report.pdf
ExifTool Version Number      : 12.57
File Name                    : Report.pdf
Directory                   : .
File Size                    : 52 kB
File Modification Date/Time   : 2020:09:10 16:46:55-05:00
File Access Date/Time        : 2025:07:30 11:37:46-05:00
File Inode Change Date/Time   : 2025:07:30 11:33:50-05:00
File Permissions              : -rw-r--r--
File Type                    : PDF
File Type Extension          : pdf
MIME Type                    : application/pdf
PDF Version                  : 1.5
Linearized                   : No
Producer                    : Skia/PDF m87
Page Count                   : 2
XMP Toolkit                  : Image::ExifTool 12.00
Creator                      : HTB{1nt3rn4LL34Ks4r3C0mm0n}
```

Figure 3: The figure above is a screenshot of a result from Falconi's Cyber Readiness modules, in partnership with HacktheBox. In this exercise, employees saw the Exiftool command in action which provides a report for any publicly available file.

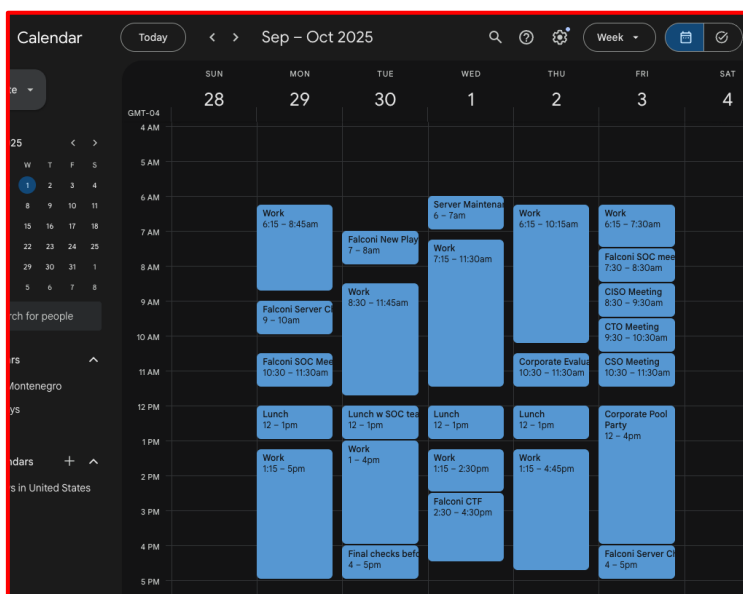


Figure 4: The figure above shows the calendar of a Falconi employee.



Recommended Mitigation Response:

- Formulate a system to centralize logging of file access, downloads, email sends, and all possible venues of possible leak data.
- Enforce authentication on all internal apps, so no unauthenticated endpoints remain
- Ensure internal apps are only reachable from Falconi's VPN by using internal-only DNS and IP whitelisting.
- Monitor for subdomain exposure and misconfigured security headers.

Exposed Services

Possible Exploitations:

Exposed services on public acknowledged infrastructure poses a modicum of serious security risks especially when those services are misconfigured or outdated. Today, attackers commonly scan open ports within company systems to infiltrate these systems. Once these systems are discovered, the services of the company can be exploited through brute force attacks to compromise systems. Accidental exposures refers to publicly accessible network services that were not intended to be reachable from the internet which creates a major security risk if accessed.



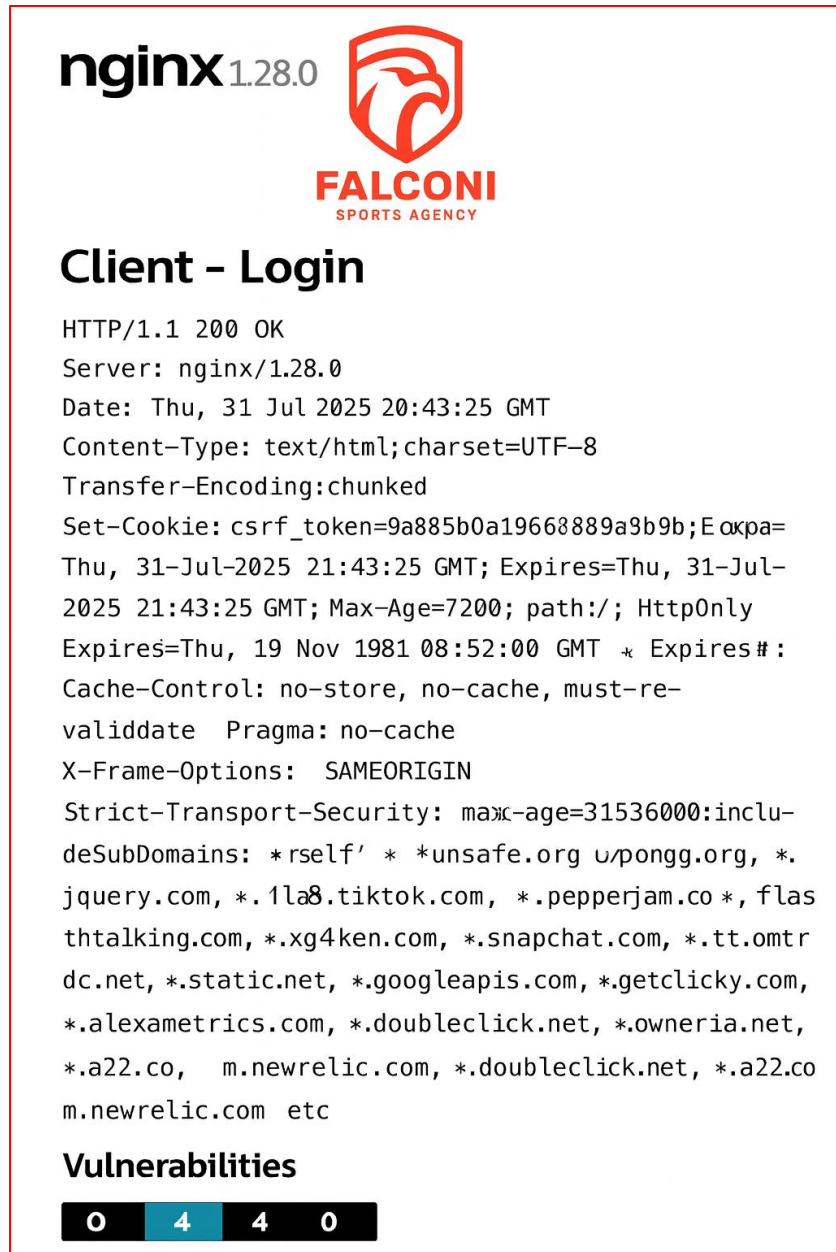


Figure 5: The image above depicts the publicly accessible login page for Falconi. The header includes client login details which represents an accidental exposure. This image showcases 4 low known vulnerabilities that the service is exposed and at risk for potential threats as well as 4 medium known vulnerabilities. Figure 5 represents an

exposed service showcasing publicly accessible data, leaking technical and version details, connection to third party services, and 4 vulnerabilities done by the scan.

Recommended Mitigation Response:

- Conduct regular audits
- Firewall any unnecessary services
- Reinforce authentication techniques
- Apply the principle of least privilege
- Enable logs and real time monitoring to ensure detection of unauthorized access attempts
- Keep updating servers with security patches



Social Networks

Social networks like X (formerly Twitter) can be exploited by bad actors to obtain valuable company information. Bad actors can collect large volumes of information and data through an organization's social network(s). For example, information like date and timestamps for postings can reveal what time zone the organization is posting from, leading to where the company is located and more. Company social networking sites tend to post about noteworthy employees and their accomplishments, potentially creating targets for further exploitation. All information being posted can be weaponized and exploited by bad actors.

Findings:



Figure 6: The above image depicts the homepage of Falconi's X (formerly Twitter) account. Notably, the number of followers is publicly accessible so anyone who follows Falconi is publicly linked to the organization. Personal information like employees' first and last names could be compromised if they follow or interact with Falconi's X account.

```

1  {
2    "data": {
3      "id": "123456789012345678",
4      "name": "Falconi",
5      "username": "Falconi",
6      "created_at": "2017-09-21T15:45:00.000Z",
7      "description": "Empowering athletes. Elevating sports.",
8      "location": "San Francisco, CA",
9      "verified": false,
10     "public_metrics": {
11       "followers_count": 14300,
12       "following_count": 312,
13       "tweet_count": 1647,
14       "listed_count": 15
15     },
16     "profile_image_url": "https://pbs.twimg.com/profile_images/abc123xyz.jpg"
17   }
18 }
19

```

Figure 7: The above image depicts publicly available information from X's API which can include valuable metadata. The username, location of the account, follower & following lists, and more are listed and can be leveraged by a bad actor.

Recommended Mitigation Response:

- Train privileged users of the Falconi social network accounts about the potential abuses and points of exploitation
- Provide training modules for all employees about the sensitivity of Falconi's social networking presence
- Implement per-user and per-IP request limits to prevent potential abuse and scraping
- Limit the exposure of employee information in public posts

Leaked Internal Files & Credentials

A public Falconi repository was found to contain several sensitive internal files. This repository included a file named creds.env, along with documents that explain Falconi's multi-factor authentication (MFA) setup, network structure, access control rules, and how data is labeled and protected. If someone with bad intentions found these files, they could learn how Falconi's security system works, figure out which accounts have high-level access, and possibly steal usernames and passwords that are written directly in the code.

Findings:

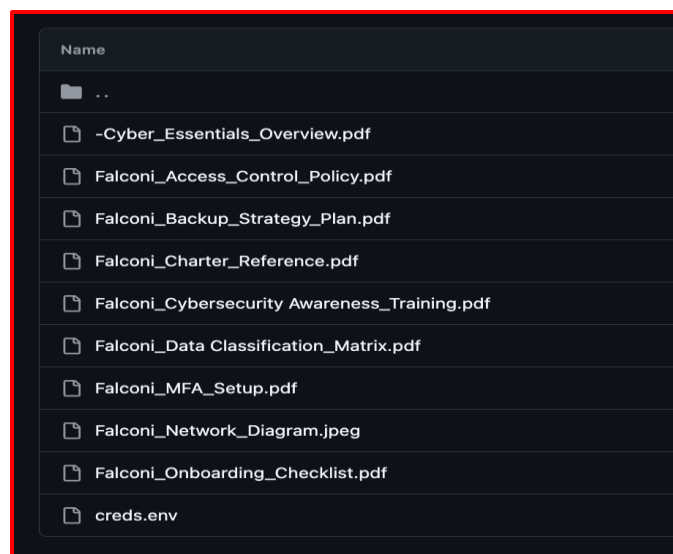
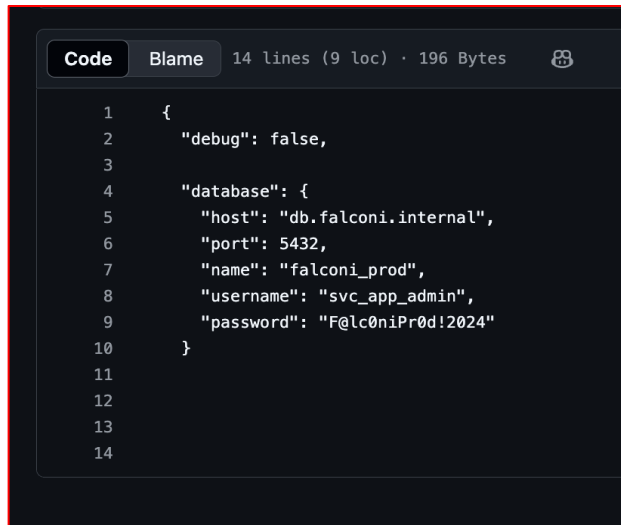


Figure 8: Screen capture of the public Falconi Github repository exposing internal strategy documents and credentials



```
1  {
2    "debug": false,
3
4    "database": {
5      "host": "db.falconi.internal",
6      "port": 5432,
7      "name": "falconi_prod",
8      "username": "svc_app_admin",
9      "password": "F@lc0niPr0d!2024"
10   }
11
12
13
14
```

Figure 9: Screen capture of Falconi database leaked credentials seen in “creds.env”

The creds.env file is especially risky because it might contain important secrets like API keys and database login information in plain text. When combined with the Falconi_Network_Diagram.jpeg, which likely shows how Falconi’s internal network is set up, attackers could figure out where important systems are and how to move between them.

Other files like Falconi_MFA_Setup.pdf and Falconi_Access_Control_Policy.pdf may also give away details about how employees log in, what tools are used for identity verification, and how different users are grouped. This kind of information could help attackers plan phishing attacks or take advantage of weaknesses in Falconi’s system.

Recommended Mitigation Response:

- Immediately delete any sensitive files like creds.env from the repo’s history
- Change or reset any credentials or API keys that were exposed

- Add a .gitignore file to prevent secret files from being tracked in the future
- Teach developers to avoid putting passwords or sensitive info in code
- Move sensitive documents to a secure, internal storage system

Cloud Storage

Open-source intelligence revealed that Falconi may have exposed or misconfigured AWS S3 cloud storage, identifiable through URLs like s3.amazonaws.com or region-specific variants. These exposures can stem from Falconi's own web assets, third-party platforms, or passive DNS records. Misconfigured S3 buckets pose multiple risks: they may expose sensitive data, internal code, or credentials; reveal internal structures useful for reconnaissance; violate data residency regulations if hosted outside Falconi's jurisdiction; and enable brand abuse through deceptive bucket naming. As over 95% of cloud vulnerabilities result from misconfigurations, even read-only access to such storage significantly increases Falconi's attack surface.

Findings:

```

93         "mayor": {
94             "count": 16,
95             "user": {
96                 "id": "[REDACTED]",
97                 "firstName": "[REDACTED]",
98                 "lastName": "[REDACTED]",
99                 "photo": "http://[REDACTED].s3.amazonaws.com/[REDACTED]/[REDACTED].jpg",
100                 "gender": "[REDACTED]",
101                 "homeCity": "[REDACTED]"
102             }

```

Figure 10: JSON response revealing a publicly accessible Amazon S3 URL hosting user photo metadata. This illustrates how misconfigured cloud storage can expose sensitive information through open-source intelligence (OSINT) techniques.

Recommended Mitigation Response:

- Audit all S3 buckets to ensure they are private by default; disable public access exceptions unless justified
- Apply least privilege using IAM roles and fine-grained access controls

- Enable Access Control Lists, Bucket Policies, Service Control Policies, and Public Access Blocks
- Regularly review AWS legal agreements and cross-border data handling terms
- Use OSINT tools (e.g., GrayHatWarfare, Rapid7) to detect exposed or spoofed Falconi cloud assets
- Confirm proper Web Application Firewalls (WAF) and Intrusion Detection/Prevention Systems (IDS/IPS)

Conclusion

This assessment reveals that many of Falconi's current risk exposures, ranging from leaked internal files to misconfigured cloud assets, are rooted in preventable issues that adversaries can exploit through open-source intelligence. As a sports agency entrusted with highly sensitive data, Falconi must take a proactive approach to cybersecurity by addressing these vulnerabilities, enforcing strict access controls, and strengthening monitoring across its digital environment. By learning how attackers leverage OSINT to uncover weaknesses, Falconi is better positioned to harden its systems, minimize exposure, and maintain trust with clients and stakeholders.

